OpenKeys R0.4 制作说明书

目录

1. 先回答：理论上能否安全
2. 最省设备投入的制作方式
3. 第一步：取得同一版本的文件
4. 第二步：把原材料分成四组
5. 第三步：确认个人、小批量接单并询价
6. 第四步：订 PCB，参数怎样填
7. 第五步：备料、客供与收料
8. 第六步：代焊与后焊
9. 第七步：首板上电与电气诊断
10. 第八步：外壳试装和 NFC 调谐
11. 第九步：完整固件、配对及生产配置
12. 第十步：功能、安全和逐台验收
13. 第十一步：收货和真实账户使用
14. 你现在可以执行到哪里

从原材料、订 PCB、代焊、结构装配，到工程验证和三把成品验收。

版本：2026-11-10。对象：没有焊接和调试设备、希望委托工厂制作的个人用户。目标是最后获得 K01、K02、K03 三把日用密钥；开发板及破坏试验样品另计。

下载打印版 PDF；PDF 来源与摘要。

制造入口 · 当前进度 · 理论安全判断 · 给工厂的订购单 · 完整安全测试

> **当前是工程样板制作指南，生产放行仍为 BLOCKED。** 现有文件可用于评审、询价和工程样板，不能据此直接取得三把可用、安全的成品。完整生产固件、真实管理通道、生产配置和实物安全资格仍未完成。本说明把后续成品工序也列出，但不提供不存在的生产镜像、配对工具或熔丝参数。

1. 先回答：理论上能否安全

架构方向有条件可行；当前实现未达到可确认安全的状态。 这里的安全必须限定攻击者能力、预算和所信任的组件。

你希望抵御的情况	理论判断	本项目当前证据
恶意电脑、伪造 USB / NFC 管理请求、重放、未授权读取	可以通过设备端认证、可信启动、隔离、请求绑定及确认建立防护	有软件策略 / 模型测试；完整硬件运行时和认证管理通道未接通

你希望抵御的情况	理论判断	本项目当前证据
设备遗失，攻击者没有有效指纹	可以采用密钥非导出、持久限次、调试关闭、配对和防拆降低风险	生物识别、持久状态、调试 / 生命周期和整机实测未完成
有明确预算的降压、EM 故障和功耗 / EM 侧信道	可以制定抵抗目标并独立验证，不能仅靠器件名称推定通过	实物测试 NOT_RUN；外部监控器不能覆盖所有快速故障
主控受保护域已被完全攻陷，仍要求其绝不能伪造指纹证明	**当前对称指纹协议不能提供该保证**	主控持有共享配对密钥，可能构造合法传感器方向消息；需评审不同的独立证明 / 授权架构
不限设备、预算和时间的所有物理攻击	不能对这种无限范围作绝对保证	没有这样的证明或认证

当前 SE_EN 电路只在复位 / 故障时禁止 SE，并不直接识别指纹。若目标是由硬件阻止不可信主机绕过受保护的指纹验证器，可以依靠正确部署的启动根与 MCU 隔离建立路径；若目标还包括抵抗已被控制的 Root 本身，单纯再加 AND 门或“匹配 GPIO”不能补足上述协议边界。

制作正式密钥前至少应关闭以下事项：

1. 生产可信启动、签名更新、防降级、调试生命周期和真实 SAU / GTZC / DMA / 外设隔离。
2. 真实传感器 / SE 身份与每设备配对，持久 PIN / 指纹管理，密钥与重置生命周期。
3. USB / NFC 的完整认证器运行时，以及认证加密的管理通道和可信确认路径。
4. 指纹误接受与假指纹、传感器 GCM IV、快速故障、侧信道和防拆绕过的实际评估。
5. 每把设备的功能、电源、结构、生产配置和修复复测证据。

Rust、加密算法、安全芯片、191 项软件测试或零 ERC / DRC 都不独立证明整机安全。指纹本身也有误接受和呈现攻击风险；有效加密匹配帧不等于绝对真实的合法手指。用户主动释放给恶意主机的 notes / 恢复码明文，也不能继续对该主机保密。

完整风险与边界见对抗性复核。器件功能依据包括 ST H573 官方说明、NXP SE050 官方说明及FIDO 生物识别文档；这些组件的能力不转移为本项目整机认证。

2. 最省设备投入的制作方式

你采购的是 **PCB 制造服务 + 元件 + 装配 / 测试服务**。不用自己购买覆铜板、蚀刻剂、钢网、锡膏或回流炉；由代工方提供并计入报价。也不需要为了三把钥匙购买故障注入或 EMC 仪器。

建议顺序：

架构预评审 → 物料与 DFM 审核 → 首块工程样板 → 电气 / 结构验证 → 完整固件集成 → 功能及安全评估 → 修订冻结 → 三把成品。

分工如下：

角色	负责什么
你	确认需求 / 报价、保管版本与收货记录、提供 Mac / iPhone 与充电器、最终账户登记与离线恢复备份
硬件工程审核 / 代焊厂	DFM、备料、双面贴片、后焊、机械试装、限流上电、仪器测试和开发烧录

角色	负责什么
固件开发	完整 Root / 协议 / 管理与生产启动、配对和更新工具；当前尚未完成
安全实验室	架构 / 源码预评估，SCA / FI / 生物识别 / EMC 等约定范围及复测

数量先这样询价： 若裸板 MOQ 是 5 片，可询“5 片裸板，先仅装 1 片工程板”。剩余裸板可在无改板且验证通过时用于后续装配。不要因为裸板 5 片就自动买 5 颗昂贵指纹模块。

工程板 E01 不自动算入三把日用密钥。只有它未受破坏性攻击、状态可可信清除 / 重新配对、且最终完全复验通过时，才可评估能否作为 K01；当前没有已交付的完整重配流程，因此预算优先把 E01 和三把成品分开。实验室可能另需牺牲板，数量由书面方案决定。

3. 第一步：取得同一版本的文件

3.1 下载并记录版本

有 Git 时，在 Mac 终端运行：

```
git clone https://github.com/Jay-Void-BA/OpenKeys.git
cd OpenKeys
git rev-parse HEAD
python3 hardware/r04/tools/manifest.py --check
python3 scripts/export-manufacturing-worksheet.py --check
python3 scripts/check-diagnostic-manifest.py
```

把 `git rev-parse HEAD` 输出保存到本次工程记录。没有 Git 时，在 GitHub 打开选定的提交后下载该提交的 ZIP；解压保留整个目录，不能单独拼凑不同日期的 BOM、Gerber 和固件。

本说明的硬件依据是 R0.4：PCB SHA256 为 `6c2a93a63f343cf0401eae8c92dc1da6f5db145604ee9b0e8b9bd08b76f4bde4`，BOM SHA256 为 `961394d1949b5f86e42d99c3772350bf48aff0a0e6e43b2662c5082ae55435eb`。不匹配时先核对新版设计，不能照旧参数下单。

3.2 给工厂的文件夹

文件	工厂用来做什么
Gerber / 钻孔 ZIP	加工裸板；其中含 4 层铜、阻焊、丝印、完整外形及 PTH / NPTH 钻孔
原理图 PDF	电路审核、极性与返修查线
原始 BOM	130 个设计位置的原始值和封装
板上采购工作表	采购 / 机贴 / 后焊 / DNP 分类和三把数量；工厂补完整订货号
板外采购工作表	指纹模块、电池、NTC 线束和机械件，避免重复计数
贴片坐标 CPL	126 个 SMD 位置：顶面 50、底面 76；单位 mm
尺寸图、结构源	机壳、窗口、按键、排线和电池试装

文件	工厂用来做什么
前视图、背视图	对照位号、方向与双面布局；不能据图片翻转底层坐标
给工厂的订购单	个人 / 数量 / 工艺 / 交付的书面确认
硬件验收	逐项测量和证据要求

板体 STEP 只含板体与孔，不是全部元件的精确供应商 3D 模型。结构渲染也不是实物照片。

4. 第二步：把原材料分成四组

4.1 机贴与板上后焊元件

原 BOM 的 130 个位置不能等同于 130 件都要采购：

- **126 个 SMT 位置**需要双面贴装。
- **J2 和 U8**为板上后焊位置：J2 是电池板端连接器，U8 是 LCD。
- **J3**是生产 DNP 的内部调试位；工程板可用治具，临时排针另行约定。
- **J4**是已经画在 PCB 上的铜天线，不买“J4 连接器”或额外 NFC 线圈。

以下为重点物料；完整数量以两份工作表为准，不在此表再累加一次。

部件	固定候选或要求	三把成品净用量	采购注意
主控 U4	STM32H573RIT6，LQFP64	3	核对完整后缀、芯片 revision 和来源
安全芯片 U5	SE050E2HQ1/Z01Z3Z	3	HX2QFN20 特殊焊盘；不接受“同系列随便替代”
指纹板端 J5	Hirose FH12-12S-0.5SH(55)	3	0.5 mm 底接触；这是连接器，模块在板外表另购
LCD U8	NHD-C0216CiZ-FSW-FBW-3V3	3	16×2、I2C、白背光；不能换常见 5 V 1602 + 转接板
Flash U6	W25Q64JVSSIQ	3	封装、容量与 JEDEC 型号需一致
NFC U7	FM11NC08S-DN-T-G 候选	3	核对具体封装与 EP、原厂图纸和供应版本
充电 / 电源	BQ25185DLHR、TPS63031DSK、TPS259470LRPWR 等	各按 BOM	不替换成外接通用充电模块
故障 / 显示复位	TPS3702CX33DDCR、SN74LVC1G07DCKR、SN74LVC1G08DCKR	按 BOM	U11 与 U15 是同型号但不同位置
USB-C J1	HRO TYPE-C-31-M-12	3	对照真实尺寸与焊盘；不是外形相似就可代换

部件	固定候选或要求	三把成品净用量	采购注意
电源开关 SW1	C&K JS102011SAQN	3	机械位置和行程须试装
按键 / 触点 SW2–SW6	TL3342F160QG	15	每把四键加一个开盖触点，共 5 个
其余 R / C / L / D / 接口	按工作表、原 BOM 和数据手册	工作表自动列出	耐压、容差、介质、功率与温度特性必须核实

当前采购表仍不是全订货号冻结表。 例如 F1 只有 250 mA 保持电流和协调待验证要求，部分阻容 / 连接器还缺完整采购型号。工厂必须填写 manufacturer、完整 MPN、料号 / 数据手册和价格；工程审核通过后才采购。不能让软件自动用“同值最便宜”替代安全或电源关键料。

特别保留：R39 / R40 的 0.1% 精度、C1 的 2 kV 额定、C29 的 C0G 与初始 56 pF 条件、功率电感的饱和电流 / 温度要求，以及所有原 BOM 注释。C29 后续按 RF 实测调谐，不是首次打样值永远不变。

4.2 板外电子件

每把另需：

1. FPC2534AM **100026230 flex 模块** 1 个。不能换 100026223 的 LGA / AP 版本，也不能换只输出普通 MATCH GPIO 的廉价指纹模块。
2. **Adafruit 1578 保护型 3.7 V / 500 mAh 电池包** 1 个，尺寸约 29×36×4.75 mm。它是工程候选，采购前核对实际供货版本、运输、保护和极性；不用裸电芯代换。
3. **Semitec 103AT-2** 真实热敏 1 个及与 J6 配套的工厂压接线束 1 套。热敏须绝缘贴合电芯，不能用固定电阻或只测环境温度。

电池自带线和板端 J2 不是同一件物料；J6 板端与 NTC 线束也不是同一件。采购单应清楚分列，避免重复买模块却漏连接器。旧指纹价格记录只是当日快照，不是本次报价或库存承诺。

4.3 机械与绝缘材料

每把需要底壳、上盖、指纹后托各 1 件；**一份 plungers STL 包含 4 个按钮柱**，三把买 3 份打印件共 12 个按钮柱。

另需 49×17.6×0.8 mm 硬化透明 PC 窗、4 个 M2 主紧固件、2 个 M1.6 指纹托紧固件、1 个绝缘 M2 触点调节件，以及绝缘垫 / 热敏贴附材料 / 电池软约束。螺钉长度、头型和螺纹方式必须实物配合后确定，不提供未经试装的统一螺钉长度。

首轮优先询非金属 3D 打印工程样件，例如 PA12 或合适的 PETG 工艺；具体材料、收缩、热和绝缘要求由结构审核确认。不要先订三套 CNC 金属壳，也不要在天线附近加金属屏蔽、螺钉或导电涂层。未验证前不灌封电池和整板，否则可能影响散热、RF、安全检修和返修。

4.4 工厂提供的耗材与设备

让报价含钢网、锡膏、双面回流、清洗、AOI、必要 X-ray、周转治具、线束压接及测试工时。工厂应有显微镜、限流电源 / 电池模拟器、万用表、示波器、SWD 调试器；RF 调谐需要 VNA 或委托具备能力的机构。

你准备 Mac、待测 iPhone、合规 USB-C 数据线和 Apple 20 W USB-C 充电器即可；三平台 / Android 测试可借设备。不要为了三把购买整套 SMT 或物理攻击仪器。

5. 第三步：确认个人、小批量接单并询价

使用已核实的公开候选与限制，先问个人合同 / 付款、3 把目标、裸板与装配 MOQ、后焊 / 结构 / 测试范围。

已经用 iCloud 向 Seeed Fusion、华秋、泰尔无锡、atsec 北京和 SGS Brightsight 提交资格询问，见联系进度。发件记录不是接受委托的证据；目前没有项目已确认接单的依据。

可选择全代料或混合代料：一般让工厂采购通用阻容和有追溯来源的普通器件；特殊指纹、LCD、电池可在工厂书面接受客供后自购直寄。自购前确认收料地址、少量器件损耗、退料、失件责任和报价有效期。

要求费用分成以下项目，避免把裸 PCB 便宜误当成整机便宜：

费用	必须问清
PCB / 工程边 / 钢网	裸板最少数量、两面钢网及一次性费用
元件	净用量、采购 MOQ、贴片损耗、替代审批、余料退回
机贴 / 后焊	两面分别费用，LCD / J2 / 线束是否另算
结构 / 整机	首件试装、材料、紧固件与返修
调试 / RF / 功能	烧录、仪器、天线调谐、逐台记录，是否包含治具
安全测试	预评估、专项、额外样品和修复复测单列
商务条件	最低收费、税运、排期、超损与返工边界

省钱优先用先做一块、工厂现有仪器、普通非金属外壳和合并备料；不通过改用无认证指纹 GPIO、删 SE、短接监控器或提前锁熔丝省钱。

6. 第四步：订 PCB，参数怎样填

先完成 DFM 和报价确认，再付款；本说明不执行采购下单。给厂商的是完整 Gerber ZIP，不能用渲染图、仅 STEP 或旧版 floorplan 代替。

6.1 直接核对的板参数

项目	本板事实 / 询价填写方式
层数	4 层：F.Cu / In1.Cu / In2.Cu / B.Cu，层序不能颠倒
厚度	1.0 mm 候选；厂商给实际公差及叠层
外形	主体 **68×92 mm**；顶部另有 **12×2.5 mm** 凸出；完整外包络 **68×94.5 mm**，不含工程边
外形依据	按 Gerber 外形中心线。KiCad 包含 0.05 mm 描边的显示边界可能约 68.05×94.55，不要据此缩放
材料 / 铜厚	首轮可询 FR-4、1 oz 铜的常规方案；具体 Tg、介质 / 铜厚和阻焊参数未冻结，需工程审核

项目	本板事实 / 询价填写方式
表面处理	首轮建议询无铅 ENIG 方案，结合细间距焊接与厂商 DFM；不是未经审核的既定材料栈
最小线 / 间距	0.15 / 0.15 mm，不能以厂商“放宽工艺”为由改有源单板铜形
普通过孔	典型 0.60 mm 铜盘 / 0.30 mm 孔，孔表以文件为准
钻孔	独立 PTH、NPTH；不能把不镀孔统一改成金属化孔
阻焊 / 丝印	用交付文件；普通颜色即可，RF 区不能额外加金属码 / 铜字 / 地平面
电测	逐板开短路电测，保留不良 / 返工记录
拼板 / 工艺边	由厂商提案，保留真实单板、器件突出和 RF 禁布区；不得裁掉顶部凸出
数量	问“5 裸板、先装 1 片”的可行性；不是默认装 5 把

完整外形应由平台预览识别。若识别成简单 68×92 矩形、层数不对、内层缺失、孔位偏移或天线铜消失，先停在工程审核，不点“按默认生产”。

6.2 工程审核必须回答的事

1. 实际叠层 / 介电参数下，USB 差分几何是否满足设计需要；90 Ω 可作为复核目标，但本板尚无厂商阻抗批准结果。
2. SE050 特殊中心焊盘、FM11NC08S EP、BQ25185 / eFuse 等封装与供应商实物一致，钢网开窗 / 锡量可接受。
3. 双面器件的回流顺序、掉件支撑、USB 机械固定、手工后焊和治具可达性。
4. NFC RF 区不新增地铜、金属件、电池、工艺支架或铜日期码；不能改线圈作为“拼板优化”。
5. 若仅加外部工艺边 / 拼板，保存厂稿并与原单板叠图核对；若改了有源单板电路、铜形、封装或尺寸，必须回项目修订、重做检查与摘要，不能继续使用旧固件契约。

7. 第五步：备料、客供与收料

先下载采购表副本，另存为本次工程报价表，再由工厂补全其中的 `approved_manufacturer`、完整 MPN、供应商料号、数据手册、报价、实际采购数量和批次。仓库中的板上采购 CSV是可重新生成的空模板，不直接覆盖它；填写后的报价和个人商务资料私下保存。所有“candidate / required”状态都不是采购批准。

优先原厂或可追溯授权渠道。收货时核对标签、封装、数量、批次和运输状态；芯片的外观检查不能替代后续身份 / 安全配置验证。可疑来源的安全芯片、指纹模块或电池不因价格低而使用。

损耗和 MOQ 不由本表自动加 10% 等比例：不同器件有最少上机料带、散料处理和采购包装要求。普通阻容按工厂合理损耗供料；昂贵模块按逐颗点收约定，先只购买工程板所需数量更稳妥。

每袋 / 盘标明本次工程编号、MPN 和数量；附客供清单，先取得工厂收料确认。不要邮寄生产密钥、真实账户、PIN、指纹模板或恢复码。

8. 第六步：代焊与后焊

8.1 双面 SMT

上传原 BOM 和 CPL 后让工厂先出贴装预览。CPL 原点来自 KiCad 辅助原点 (100,172) ㎜，导出已使用该原点；不手工镜像底层、不自行将所有坐标改成外壳坐标。工厂应通过位号、两面图、孔和非对称器件逐项核对坐标与旋转定义。

顺序由工厂根据器件数据手册、受潮等级和实际工艺确定。126 个 SMD 位置为顶面 50 / 底面 76，不是“单面贴完即可”。回流温度曲线不得用一份未经核对的通用数值覆盖所有器件。

要求 AOI、关键引脚 / 极性检查及 QFN / EP 等必要 X-ray 或其他认可检查。焊好保留照片和缺陷 / 返修记录；不是仅提交“通电亮屏”的视频。

8.2 回流后再安装的部分

1. 后焊 J2 板端电池连接器和 U8 LCD，核对玻璃支撑、I2C 引脚以及独立背光 A / K 线。
2. 断电打开 J5 锁扣，再按原厂规定插入正确接触面的 100026230 flex，扣好并检查导通；不以外观相似判断正反，不硬折排线。
3. 由工厂做好 NTC 压接线束，绝缘贴合电芯；软包不直接加热焊线。
4. **电池暂不接入**。先做无电池限流上电和极性检查，合格后再接保护包。

J4 无独立器件，J3 不作为生产常驻外露插座。USB-C 是唯一外部数据 / 充电母口，不另装外露调试或电池插口。

9. 第七步：首板上电与电气诊断

本步由工厂或具备仪器的工程师操作；你无需自行练习 QFN 返修或故障注入。

9.1 未接电池前

对照网表确认 J2.1=BAT+、J2.2=GND，实际测量电池插头极性；不只看线色。检查短路、器件方向、LCD A / K、指纹排线接触面和 VCAP 无外部负载。

裸板未装盖时，SW6 处于开盖状态，会通过独立电路拉低复位。工厂需在**不含用户秘密的工程板**上用治具临时按压 SW6 模拟合盖，并将主开关置 ON，才能进行正常启动 / 诊断；松开治具应触发相应复位和清屏。不要把复位线强行拉高或留下永久短接，最终必须用真实盖板重新验收。

使用限流电源 / 电池模拟器上电，记录 SYS、3.3 V、LCD_3V0、TAMP_3V0、VCAP1 / VCAP2、启动电流和温度。限流值、波形与阶段由审核工程师按实际负载 / 器件要求确定，不能把“没有烧坏”当通过。

再测复位、开盖和电源故障时的 NRST、SE_EN、LCD_RESET_N。供电异常不得产生私密授权；TPS3702 的典型响应不是纳秒故障抵抗保证。

9.2 只能在空白开发板上烧现有诊断

可用镜像是 openkeys-r04-diagnostics.elf，配套 BIN 和来源清单在同目录。它要求 OPEN / TZEN=0 的空白测试设备，**不是生产认证固件**。不在已配置 / 已关闭设备上降级安全状态来运行它。

工厂使用其支持 H573 的 SWD 设备和程序加载 ELF、验证写入，并记录工具 / 芯片版本与镜像摘要。无需通过 USB-C 刷写；本镜像没有交付 USB 引导烧录功能。程序员的电源输出与板供电不能未经确认并联；J3.1 是 +3V3 / 电平参考，不能输入 5 V。

实际网表的 J3 定义：

J3 引脚	信号	用途
1	+3V3	电平参考；供电方式须由治具确认
2 / 4	SWDIO / SWCLK	调试数据 / 时钟
3 / 5 / 9	GND	公共地
6	SWO	可选跟踪
7 / 8	不连接	不擅自接其他信号
10	NRST	复位

原理图 / 封装的 pin1 与实际治具逐一核对，不只按插头缺口猜方向。工程治具或临时排针的使用不等于允许最终秘密存在时保持调试开放。

诊断应显示 `DIAGNOSTIC ONLY`，核对 Flash JEDEC、白背光和四键释放事件；开盖 / 电源故障应清屏 / 复位并进入安全状态。它**不启用 SE、指纹、充电、USB 枚举或 NFC 功能**。因此此阶段不能测 FIDO 登录，也不能把“不充电”改为硬件短接充电使能。

9.3 接电池与充电资格

极性、保护包、NTC 和电源记录通过后再由工厂接入电池。现有诊断不提供正常充电服务；完整电源 / USB 挂起固件完成后才能验收充电工况。

设计使用 Apple 20 W 充电器的 **5 V** 档，输入预算 100 mA，约 **0.50 W**；电池充电目标最大 100 mA，4.2 V 时约 **0.42 W**，不请求 9 V。系统负载会降低实际充电，活跃负载时也可能由电池补充。500 mAh / 100 mA 的理想容量比为 5 小时，不能据此承诺实际充满时间或寿命。

模拟 NTC 开路、短路和越温，测停止充电；再验证 USB 挂起、反灌、热和电池工作状态。不能为了“兼容 20 W”提高到未经审核的电压 / 电流。

10. 第八步：外壳试装和 NFC 调谐

先做一套壳体，验证 PCB 支撑、USB 单口、滑动开关、LCD、指纹托、四个按钮柱和 SW6 开盖触点。调整触点与按钮行程不能靠挤压电池、LCD 玻璃或排线实现。

电池包按预留空间用绝缘软约束固定，保留膨胀和线束余量；不压软包、不用长螺钉穿入电池或 RF 区。指纹排线有自然弯曲，不能被后托夹伤。窗口和材料尚无防水 / 防尘等级资格。

普通 SW6 触点可以被桥接，不因装壳就宣称主动防拆网格已实现。开盖、关机 / 电池供电、备用域丢失均需按计划测试；若威胁等级要求更强结构，先改设计再完成最终三套。

在**最终壳体 + 电池 + 典型手握条件**下用 VNA 测线圈并调整 C29。1.20 µH / 56 pF 只是首轮模型，不是最终参数。保存每版匹配值、波形、材料和距离 / 方向记录。NFC 登录和手机管理分别真机验证；手机磁场不为整机指纹 / LCD 提供充足电力，设备需要自己的电池 / 电源。

11. 第九步：完整固件、配对及生产配置

本步当前尚不能执行为成品工序。 对应生产镜像、完整管理后端、部署和配对工具没有交付；不能用 `cargo check` 通过、测试 Env 或诊断 ELF 代替。

以后需要准备并评审：

交付物	必须满足
生产 ARM ELF / BIN	匹配冻结硬件、可重现构建、完整 FIDO / vault / 管理 / 电源功能
启动与签名更新配置	真正的可信启动、防降级、更新中断恢复、正确隔离和调试策略
受控个性化流程	每台唯一 SE / 指纹配对和秘密；拒绝默认密钥、普通 Flash counter 或 UID 当密钥
设备端初始化	仅无用户秘密的空白状态可执行；已配置设备断电不重开初始化
三平台管理器	真设备身份与加密管理通道、失焦 / 拔线 / 休眠撤权、真实导入 / 删除
手机端	若交付，须有真实 APK / IPA、签名及 NFC 管理验证；当前只有实现前提

签名私钥、生产秘密和真实用户指纹不能随代焊资料发送。建议普通代焊结束于工程烧录 / 电测；最终安全配对 / 个性化由你控制的受信工序完成。不得把多个设备克隆成同一密钥。

先在牺牲样件验证启动 / 更新 / 生命周期，再在成品执行经审核的配置。此处不列通用“锁死芯片”命令；H573 具体状态、恢复和不可逆行为须由实际 profile 决定。提前永久关闭调试不等于完成安全性，只会增加返工风险。

PIN 固定为实体四键的 12 符号序列：短按 1–4 输入、长按 4 删除、长按 2 取消；菜单 Previous / Next / Confirm / Cancel。它只在指纹之后作为附加条件，没有 PIN 备用解锁。生物识别 / 配对故障时不得通过工厂后门读取旧秘密；维护与恢复生命周期也必须评审。

12. 第十步：功能、安全和逐台验收

先用合成账户 / 假恢复码，不把真实账户带进实验室。至少执行：

1. 未指纹、仅 PIN、错误指纹 / PIN、取消、超时、断连、换 USB / NFC 通道、挂起 / 复位都不能获得私密输出或权限。
2. 全部 RP 身份分页、账户选择、批准 / 取消与实际操作相同；U2F 显示可核对应用哈希。
3. macOS / Windows / Linux USB 和 iPhone / Android NFC 按系统、客户端、协议分别测试，不用一个“支持 iOS”概括所有功能。
4. FIDO2 / U2F / hmac-secret、SSH / Git 使用实际支持的客户端验证；notes / recovery 的列表、导入、显示、删除均受设备授权，旧密文 / 断电 / 错记录不被放行。
5. 启动 / 调试 / 更新 / 持久预算 / 断电事务以及电源、开盖、备用域和充电的实物检查。
6. 实验室按约定预算执行 SCA、分域降压 / EM 等 FI、指纹 PAD / FAR / FRR 和 EMC；未见异常只支持该版本、样品和范围，不是所有攻击不存在的证明。

未验证指纹却得到有效签名、hmac-secret、私密明文或管理 / 调试权限，即判失败。发现失败先保留证据、修复并复测，不能改检查器把失败变成 PASS。详细编号和方法见完整安全测试计划。

K01、K02、K03 每台独立记录：PCB / 器件版本、固件提交 / 摘要、配置、配对状态、仪器 / 步骤、PASS / FAIL / NOT_RUN、波形及返修 / 复测情况。开发 E01 / 受攻击样件的结论不能未经评估外推成三把日用设备已通过。

最后运行 `python3 scripts/check-production-ready.py`。当前应为 **2 / BLOCKED**；将来文件齐全也只进入人工评审，不由脚本自动签发安全认证。

13. 第十一步：收货和真实账户使用

工厂最终应交：三把编号设备、实际装配清单和批次、原始 / 厂改工程稿、最终 Gerber / BOM / CPL、生产镜像 / 配置及摘要、逐台记录、测试与修复报告、退料和返修约定。仅有设备外观、亮屏视频或 CI 截图不够。

你收到后再用合成数据完成一轮未指纹 / 仅 PIN 拒绝、取消 / 超时 / 断线、三把分别注册登录、notes / 恢复码授权和锁定清屏。

确认完整验收后才登记真实账户。三把分别注册，不复制私钥；至少留一把异地保存。恢复码另留独立离线备份，不把唯一恢复方式全部放在同一指纹系统内。不要将个人 PIN、模板、秘密或恢复码上传 GitHub。

14. 你现在可以执行到哪里

当前动作	条件
下载、核对、整理 BOM / 订购单并询价	可以立即进行
个人、小批量合同与工程预评审	等机构书面接受；本项目已提交询问
下单首块工程板	先确认物料 / DFM、费用和工程样板范围；当前不代表生产放行
机贴、后焊、限流电测与诊断	由工厂按本说明和实际仪器记录执行
直接烧当前诊断后当安全密钥使用	不具备对应功能与安全条件
三把生产个性化、真实账户、正式交付	等完整固件 / 管理 / 生命周期及实物资格完成

本手册不替你下单、付款、烧录或签发认证。它给出完整工序、实际文件、采购拆分和验收条件；未完成的软件与架构工作仍是交付前的必需工作。